

Progress Report Bab 1-3 Kelompok 8

Perancangan dan Implementasi Protokol Keamanan AAA Pada Sistem Informasi Seekem

Muhammad Abyan Putra Wibowo	G6401231078
Muhammad Agung Rizkiansyah	G6401231096
Muhammad Chalied Al Walid	G6401231114

Ringkasan

Laporan Monitoring P7 ini disusun sebagai bukti kemajuan pengembangan proyek SEEKEM hingga minggu ke-7, sesuai dengan instruksi pengelolaan repositori Git pada mata kuliah KOM1315 Keamanan Informasi. Pada tahap ini, kelompok telah menyelesaikan baseline analisis sistem, threat modeling, serta rancangan awal integrasi mekanisme keamanan ke dalam aplikasi.

Hingga minggu ke-7, implementasi keamanan yang telah diterapkan pada sistem utama meliputi Authentication dan Authorization. Mekanisme authentication telah mendukung proses registrasi pengguna, login, penyimpanan kata sandi secara aman menggunakan algoritma bcrypt, verifikasi email, serta penerbitan dan validasi JSON Web Token (JWT) sebagai mekanisme autentikasi sesi. Sementara itu, mekanisme authorization telah diterapkan untuk membatasi hak akses berdasarkan peran pengguna (role-based access control), yaitu admin dan civitas, serta melakukan pemeriksaan kepemilikan data (ownership check) pada setiap akses terhadap sumber daya tertentu. Kedua mekanisme tersebut diintegrasikan langsung ke dalam alur kerja (workflow) utama aplikasi SEEKEM, sehingga tidak diimplementasikan sebagai skrip atau modul yang berdiri sendiri.

Selain itu, komponen Accounting atau audit logging juga telah mulai diimplementasikan pada minggu ke-7. Setiap aktivitas penting dalam sistem, seperti registrasi akun, login, verifikasi email, verifikasi laporan, serta verifikasi klaim, secara otomatis dicatat ke dalam tabel audit_logs pada basis data. Untuk menjamin integritas data serta mendukung aspek non-repudiation, setiap entri audit log ditandatangani secara kriptografis menggunakan algoritma Ed25519 Digital Signature, sehingga setiap catatan aktivitas dapat diverifikasi keasliannya dan tidak dapat dimodifikasi tanpa terdeteksi.

1. Pendahuluan

1.1. Latar Belakang

SEEKEM merupakan platform digital berbasis web yang dirancang untuk memfasilitasi pengelolaan laporan barang hilang dan barang temuan di lingkungan IPB University. Sistem ini

dikembangkan dengan pendekatan Security by Design, sehingga aspek keamanan telah menjadi pertimbangan utama sejak tahap perancangan. Arsitektur keamanan SEEKEM berfokus pada penerapan kerangka AAA (Authentication, Authorization, dan Accounting) sebagai fondasi dalam melindungi data serta mengendalikan akses pengguna.

SEEKEM mengelola berbagai informasi yang bersifat sensitif, seperti nama, Nomor Induk Mahasiswa (NIM), alamat email, nomor telepon, serta bukti pendukung dalam proses klaim barang. Oleh karena itu, sistem memerlukan mekanisme keamanan yang memadai untuk menjaga kerahasiaan, integritas, dan akuntabilitas data. Beberapa risiko yang berpotensi muncul meliputi pencurian akun (account hijacking), akses tidak sah terhadap data sensitif, manipulasi status laporan maupun klaim, kebocoran informasi pribadi pengguna, serta tidak tersedianya jejak aktivitas (audit trail) ketika terjadi insiden keamanan.

Monitoring P7 difokuskan pada evaluasi perkembangan awal proyek, yang mencakup hasil analisis kebutuhan keamanan, penyusunan rancangan mekanisme perlindungan sistem, serta implementasi awal kontrol keamanan yang telah terintegrasi ke dalam aplikasi. Hasil monitoring ini diharapkan dapat memberikan gambaran mengenai tingkat kesiapan implementasi keamanan SEEKEM sekaligus menjadi dasar untuk pengembangan fitur keamanan pada tahap selanjutnya.

1.2. Tujuan Laporan

Tujuan laporan Monitoring P7 adalah:

- Menjelaskan kondisi dan kebutuhan keamanan SEEKEM sampai minggu ke-7.
- Merangkum hasil analisis sistem dan ancaman utama.
- Mendokumentasikan progres implementasi Authentication dan Authorization.
- Mendokumentasikan progres awal implementasi Accounting (audit logging dengan digital signature).
- Menjadi baseline sebelum pengembangan keamanan lanjutan pada minggu berikutnya.

1.3. Ruang Lingkup

Ruang lingkup monitoring mencakup:

- Analisis kebutuhan keamanan sistem SEEKEM.
- Threat modeling untuk aktor civitas, admin, dan pengguna tidak sah.
- Progres integrasi Authentication ke backend dan frontend.
- Progres integrasi Authorization berbasis role dan ownership.
- Progres awal Accounting berupa audit logging dengan tanda tangan digital Ed25519.
- Rencana lanjutan untuk enkripsi data sensitif dan pengujian end-to-end.

Ruang lingkup ini belum mencakup implementasi lengkap enkripsi field-level untuk seluruh data sensitif, maupun log pengujian end-to-end yang komprehensif.

2. Analisis Sistem dan Risiko

2.1. Ringkasan Sistem

SEEKEM memiliki dua aktor utama:

Aktor	Peran dalam Sistem	Data atau fitur yang perlu dilindungi
Civitas akademika	Melaporkan barang hilang/temuan, mencari barang di etalase, mengajukan klaim, dan mengonfirmasi barang ditemukan	Profil pribadi (nama, NIM, email, nomor telepon), data laporan, riwayat klaim, bukti kepemilikan
Admin platform	Memverifikasi laporan masuk, menyetujui atau menolak klaim, dan mengelola item yang dipublikasikan	Data seluruh pengguna, data laporan, data klaim, log audit aktivitas sistem

Alur utama sistem dimulai dari pengguna yang mengakses frontend (React/Vite), mengirim request ke backend API (FastAPI), lalu backend melakukan validasi dan mengambil atau memperbarui data pada database PostgreSQL. Berdasarkan analisis awal, titik kontrol keamanan utama berada pada proses registrasi, login, validasi token JWT, pengecekan role, pengecekan ownership, pencatatan audit, dan perlindungan data sensitif.

2.2. Aset yang Dilindungi

Aset penting yang diidentifikasi pada tahap analisis meliputi:

- Akun pengguna, termasuk email, password hash, dan role (admin/civitas).
- Profil civitas, termasuk nama, NIM, dan nomor telepon (dienkripsi di database).
- Data laporan barang hilang dan temuan beserta foto dokumentasi.
- Data klaim beserta bukti kepemilikan dan informasi kontak pengklaim (dienkripsi di database).
- Konfigurasi keamanan seperti `JWT\_SECRET\_KEY`, `FIELD\_ENCRYPTION\_KEY`, dan `AUDIT\_SIGNATURE\_PRIVATE\_KEY`.
- Bukti aktivitas pengguna yang dicatat melalui audit log beserta tanda tangan digital.

2.3. Risiko Utama

Hasil threat modeling menunjukkan beberapa risiko prioritas:

Risiko	Dampak	Mitigasi yang Direncanakan
Authentication yang lemah	Pengambilalihan akun pengguna (<i>account takeover</i>).	Password di- <i>hash</i> menggunakan bcrypt , validasi login, penggunaan JSON Web Token (JWT) dengan <i>token expiration</i> , serta verifikasi email.

Endpoint tidak membatasi <i>role</i> pengguna	Pengguna civitas dapat mengakses fitur admin atau sebaliknya.	Penerapan Role-Based Access Control (RBAC) untuk membedakan hak akses antara admin dan civitas.
Tidak adanya <i>ownership check</i>	Pengguna dapat mengklaim laporan miliknya sendiri atau mengonfirmasi laporan milik pengguna lain secara tidak sah.	Validasi kepemilikan data (<i>ownership check</i>) pada sisi backend sebelum setiap proses klaim atau perubahan data.
Password disimpan secara tidak aman	Password dapat bocor apabila database terekspos.	Password disimpan dalam bentuk <i>hash</i> menggunakan algoritma bcrypt dengan <i>auto-generated salt</i> .
Data kontak disimpan dalam bentuk <i>plaintext</i>	Nomor telepon dan informasi kontak dapat bocor apabila database terekspos.	Enkripsi tingkat field (<i>field-level encryption</i>) menggunakan algoritma AES-GCM .
Aktivitas penting tidak tercatat	Investigasi insiden keamanan menjadi sulit karena tidak tersedia jejak aktivitas (<i>audit trail</i>).	Implementasi <i>audit logging</i> ke tabel database untuk mencatat seluruh aktivitas penting pada sistem.
Audit log dimanipulasi	Bukti aktivitas kehilangan integritas dan tidak dapat dipercaya.	Setiap entri <i>audit log</i> ditandatangani menggunakan Ed25519 Digital Signature untuk menjamin integritas dan <i>non-repudiation</i> .

2.4. Prioritas Keamanan

Berdasarkan risiko tersebut, prioritas keamanan sampai minggu ke-7 diarahkan pada tiga fondasi utama:

1. Authentication, agar sistem dapat memastikan identitas pengguna sebelum memberikan akses.
2. Authorization, agar sistem dapat memastikan pengguna hanya mengakses fitur dan data sesuai perannya.
3. Accounting, agar setiap tindakan krusial tercatat secara transparan dan anti-manipulasi.

Ketiga fondasi AAA ini telah menjadi fokus implementasi minggu ke-7, dengan Authentication dan Authorization yang lebih matang dan Accounting yang sudah memiliki fondasi awal.

3. Progres Implementasi Hingga Minggu ke-7

3.1. Status Umum Progres

Sampai minggu ke-7, kelompok telah menyelesaikan dokumen proposal teknis, threat modeling, rancangan awal keamanan, dan integrasi Authentication, Authorization, serta Accounting awal pada aplikasi. Implementasi dilakukan langsung pada alur utama aplikasi, bukan sebagai modul demonstrasi yang berdiri sendiri.

3.2. Progres Authentication

Authentication sampai minggu ke-7 telah difokuskan pada validasi identitas pengguna. Implementasi yang sudah dilakukan meliputi:

- Registrasi pengguna dengan data akun (nama, email, NIM, nomor telepon, password) dan role default civitas.
- Login menggunakan email dan password.
- Penyimpanan password menggunakan hashing bcrypt dengan auto-generated salt.
- Penerbitan access token JWT (algoritma HS256) dengan masa berlaku 7 hari.
- Validasi token JWT untuk mengakses endpoint yang membutuhkan autentikasi melalui dependency ``get_current_user``.
- Verifikasi email menggunakan token acak (``secrets.token_urlsafe(32)``) dengan masa berlaku 24 jam.
- Fitur kirim ulang verifikasi email dengan rate limiting (cooldown 60 detik).
- Reset password menggunakan token acak dengan masa berlaku 15 menit.
- Rate limiting in-memory untuk endpoint forgot-password dan resend-verification (maksimal 5 permintaan per jam).
- Integrasi token dari frontend ke request backend melalui header ``Authorization: Bearer``.

Pada backend, Authentication terhubung dengan modul ``src/auth/security.py`` (hashing dan JWT), ``src/auth/deps.py`` (dependency injection untuk mengambil current user), dan ``src/auth/auth.py`` (route register, login, verify-email, forgot-password, reset-password). Pada frontend, Authentication terhubung dengan halaman login, halaman register, dan API client yang membawa token pada setiap request.

Dengan integrasi ini, pengguna tidak hanya diverifikasi pada tampilan frontend, tetapi juga pada backend. Hal ini penting karena backend tetap menjadi titik validasi utama dan tidak mempercayai role atau identitas hanya dari input client.

3.3. Progres Authorization

Authorization sampai minggu ke-7 telah difokuskan pada pembatasan akses berdasarkan role dan ownership. Role utama yang digunakan adalah:

- ``civitas`` untuk civitas akademika (pengguna umum).
- ``admin`` untuk pengelola platform.

Implementasi Authorization yang sudah dilakukan meliputi:

- Proteksi endpoint admin menggunakan dependency ``get_current_active_admin`` yang memeriksa ``current_user.role.value == "admin"`.`
- Pembatasan akses endpoint verifikasi laporan (``/api/admin/verification``), manajemen klaim (``/api/admin/claims``), manajemen item (``/api/admin/items``), dan audit log (``/api/admin/audit-logs``) hanya untuk role admin.
- Pembatasan bahwa admin tidak diperbolehkan membuat laporan barang (``report_item``) maupun mengajukan klaim (``create_claim``).
- Ownership check: hanya pelapor asli yang dapat mengonfirmasi bahwa laporannya sudah selesai (endpoint ``confirm_lost_item_claimed``).
- Ownership check: pengguna tidak dapat mengklaim laporan miliknya sendiri.
- Pembatasan klaim hanya pada laporan yang berstatus ``published`` atau ``resolved``.
- Pemisahan route dan dashboard berdasarkan role di frontend.

Contoh integrasi Authorization adalah civitas hanya dapat membuat laporan, mencari barang, dan mengajukan klaim, sedangkan admin memiliki akses untuk memverifikasi laporan, menyetujui atau menolak klaim, dan mengelola item yang sudah dipublikasikan. Setiap endpoint yang membutuhkan autentikasi menggunakan dependency ``get_current_user``, dan endpoint admin tambahan menggunakan ``get_current_active_admin``.

3.4. Bukti Integrasi ke Sistem

Bukti integrasi Authentication, Authorization, Accounting, enkripsi, dan digital signature dapat dilihat dari struktur source code yang sudah ditempatkan pada folder ``03_Source_Code``.

Bukti tersebut menunjukkan bahwa kontrol keamanan sudah masuk ke aplikasi utama SEEKEM dan bukan merupakan skrip demonstrasi terpisah.

Kesimpulan

Sampai minggu ke-7, proyek SEEKEM telah memiliki baseline analisis dan rancangan keamanan yang memadai serta implementasi awal yang terintegrasi langsung ke sistem utama. Authentication mendukung validasi identitas pengguna melalui registrasi, login, hashing password bcrypt, JWT, verifikasi email, dan reset password. Authorization mendukung pembatasan akses berdasarkan role (admin/civitas) dan kepemilikan data. Accounting mendukung pencatatan audit trail dengan tanda tangan digital Ed25519 pada setiap entri.

Selain AAA, implementasi minggu ke-7 juga mencakup enkripsi field-level menggunakan AES-GCM untuk melindungi data sensitif (nomor telepon dan kontak) di database, serta digital signature menggunakan Ed25519 untuk menjamin integritas dan non-repudiation audit log. Test suite keamanan juga telah tersedia untuk memvalidasi fungsi enkripsi, access control, dan deteksi manipulasi data.

Fondasi keamanan ini menjadi titik awal yang solid untuk pengembangan lanjutan, termasuk perluasan cakupan audit, penguatan hash chain, dan pengujian end-to-end pada minggu-minggu berikutnya.